

Module 9

Explaining Network Security Concepts

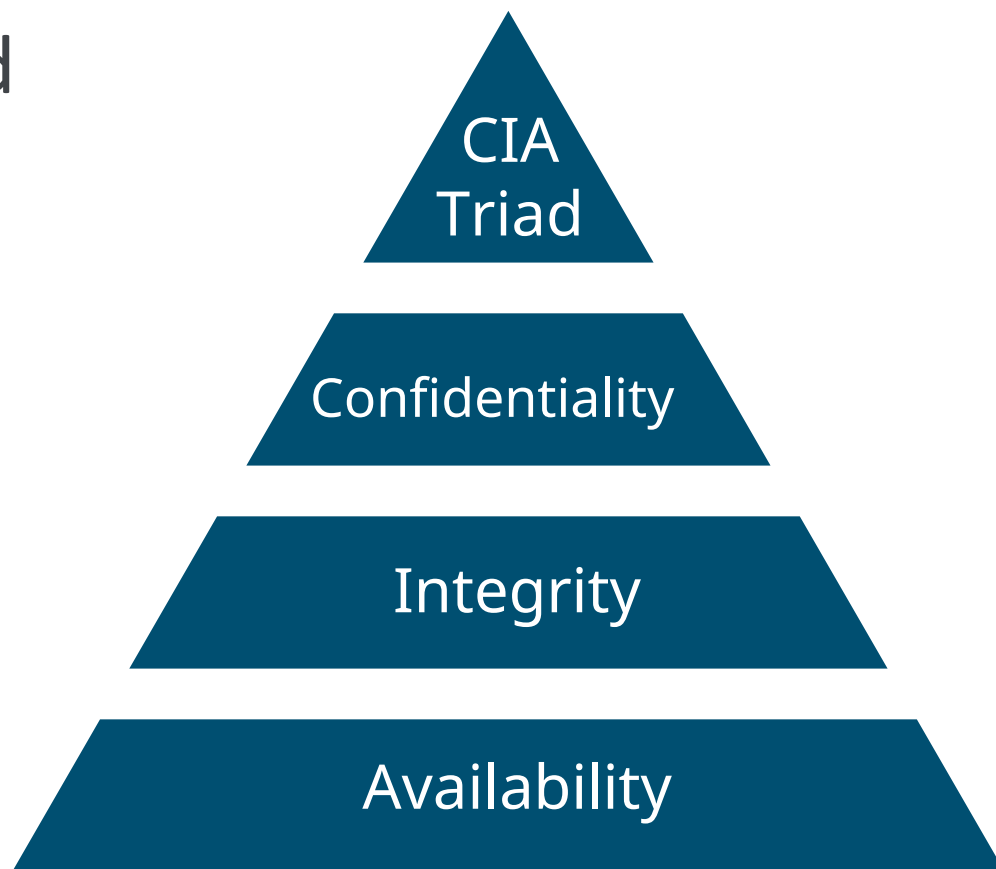
Learning Objectives

- Explain common security concepts.
- Distinguish risk, vulnerability, exploit, and threat.
- Explain the importance of audits and regulatory compliance.
- Summarize types of attacks and their impact on the network.

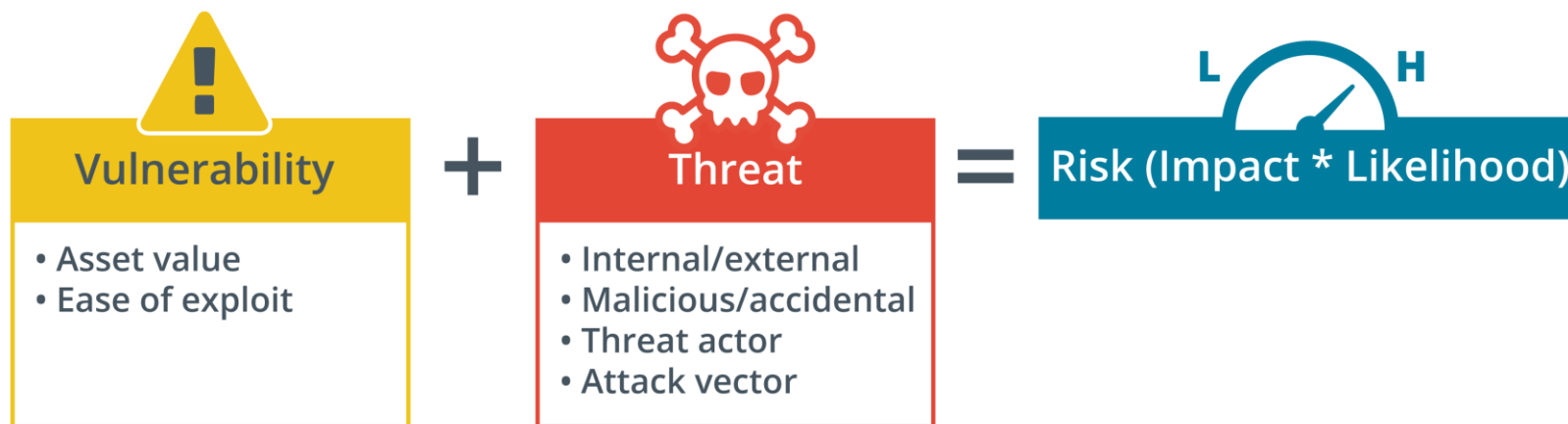
Lesson 9.1

Security Concepts

CIA Triad



Vulnerability, Threat, Risk



Security Audits

Security Audit

- Systematic evaluation of a company's information system security
- Measure conformity to established security criteria
- Identifies strengths and weaknesses
- Highlights areas for security improvement

Key Components

- Policies assessment
- Procedures review
- Technical controls evaluation
- Access controls inspection
- Risk management practices assessment

Types of Security Assessments

Compliance Audits

- Verify adherence to laws, regulations, and standards

Risk-Based Audits

- Identifying and prioritizing potential threats/vulnerabilities

Technical Audits

- Deep-dive into IT infrastructure (e.g., network security, access controls, and data protection)

Role of Risk Management

Identifying Critical Assets

- Determine mission essential functions/assets vital to business operations

Business Impact Analysis (BIA)

- Assess potential losses from threat scenarios (e.g., DoS attack)

Mitigation Strategies

- Balance cost of security controls against the potential risks to determine acceptable risk levels

Regulatory Compliance

Definition

- The process by which organizations ensure they are following all relevant laws, regulations, and guidelines applicable to their industry

Purpose

- To protect data, individuals' privacy, and ensure the integrity of financial transactions and sensitive information

Key Components

- Implementation of security measures and controls
- Regular internal and external audits
- Compliance with specific industry standards

Regulatory Compliance

General Data Protection Regulation (GDPR)

- Scope: collection/processing of personal data in the EU
- Informed consent and data rights

Payment Card Industry Data Security Standard (PCI DSS)

- Scope: organizations handling credit card transactions
- Standards for protecting cardholder data

Understanding Encryption

What is Encryption?

- Converting human-readable data (plaintext) into a coded format (ciphertext)
- Only accessible to authorized users with decryption key

Purpose of Encryption

- Ensures data confidentiality
- Protects information from unauthorized access

Types of Cryptographic Algorithms

Encryption Algorithm

- Converts plaintext into ciphertext (key required for decryption)
- Use Case: Protecting emails or files

Cryptographic Hash Algorithm

- Transforms a string into a fixed-length hash (cannot be reversed)
- Use Case: Password storage, verifying data integrity

The States of Data



Data at Rest

- Persistent storage media protection
- Example: encrypted hard drives



Data in Transit

- Protection while data is transmitted
- Example: TLS encryption



Data in Use

- Securing data in volatile memory
- Example: RAM encryption techniques

Vulnerabilities

Definition

- Flaws in software design allowing bypass of security or causing crashes

Causes

- Misconfigurations, poor practices, design faults

Impact

- Allows attackers to execute arbitrary code, install malware, compromise security configurations

Targets

- Commonly include web servers, browsers, plug-ins, email clients, databases

Types of Exploits and Vulnerabilities

Zero-Day Vulnerabilities

- Exploited before developers can patch
- High destructive potential

Unpatched/Legacy Systems

- Pose significant threats due to lack of updates or support

Vulnerability Assessment

- Evaluating a system's security based on its configuration
- Verify it matches the ideal baseline
- Involves manual inspections and automated scans

Deception Technologies

What are Deception Technologies?

- Confuse and divert cyber attackers
- Make attacks more difficult and costly

Key Components

- Honeypots: Fake systems to lure attackers
- Honeynets: Fake networks for broader trapping

Benefits

- Early attack detection via decoy engagement
- Analysis of attacker tactics for better defense
- Early warning by spotting breaches early

Placement

- Set in monitored areas between Internet and internal network

Activity: Quick Search

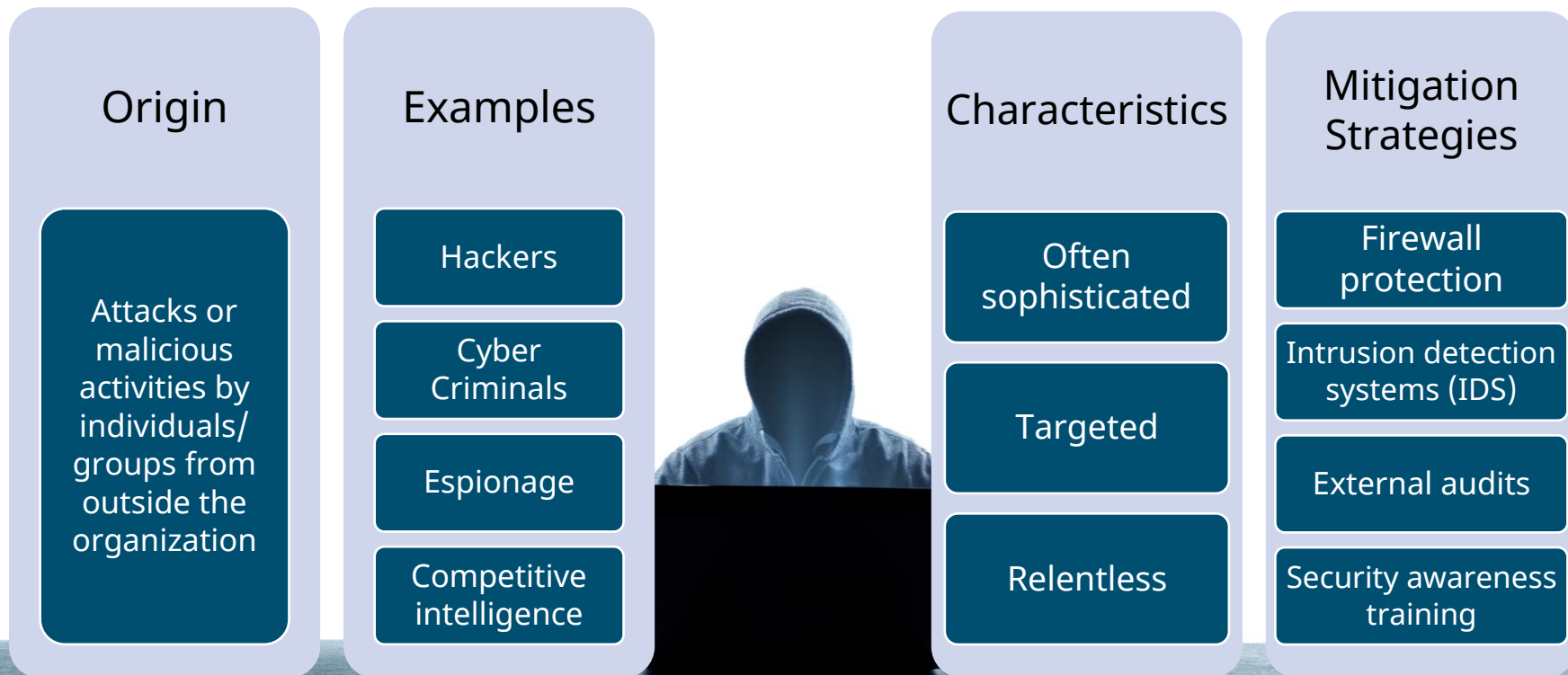
Run a quick search for
**“zero-day attacks that happened
in the last week.”**



Lesson 9.2

Network Threats and Attacks

External Threats



Internal Threats

Origin

Originate from within the organization

Often involve employees, contractors, or business partners

Examples

Accidental data leaks

Deliberate data theft

Sabotage

Insider trading



Characteristics

Harder to detect due to legitimate access

May stem from dissatisfaction, malicious intent, or carelessness

Mitigation Strategies

Role-based access controls

User activity monitoring

Regular security training

Clear policies on data handling

Enumeration Attacks



Footprinting

- Network topology discovery
- Security configurations via social engineering or port scanning



Fingerprinting

- Identifying system/software versions
- Vulnerability probing

Denial of Service (DOS) Attacks

Origin

- Internet's inception and growing more complex
- Evolved to sophisticated DDoS using botnets

Characteristics

- Intent: Disrupts service, denying user access.
- Methods: Uses resource exhaustion, bandwidth saturation, software exploitation
- Impact: Service degradation to complete shutdown

DDoS Attacks – Examples and Mitigation

Examples of DDoS Attacks

- ICMP Flood: Overloads with ICMP packets (unreachable targets)
- SYN Flood: Abuses TCP handshake (blocks legitimate server access)
- DNS Amplification: Exploits misconfigured DNS servers (attack traffic)

Mitigation Strategies

- Early Detection: Monitors for unusual traffic patterns
- Traffic Filtering: Employs firewalls and IDS to block malicious traffic
- Response Plan: Prepares specific actions for DoS attacks
- Redundancy: Implements network redundancy to reduce downtime

Botnet Attacks

Definition

Network of compromised computers for malicious use

Infected by malware and controlled remotely

Types of Botnets

Distributed Denial of Service (DDoS)

Spam botnets

Banking trojan botnets

Mitigation strategies

Implement cybersecurity like firewalls and antivirus

Analyze network for unusual traffic

Isolate and fix compromised devices

Teach safe internet use

Malware

Definition

- Harmful software disrupting or damaging systems

Types of Malware

- Viruses/Worms
- Trojan
- PUPs/PUAs

Vectors and Payloads

- Vectors: Infection and spread methods
- Payloads: Executed harmful actions (e.g., spying, unauthorized access, data encryption for ransom)

Fileless Malware

Characteristics

- Sophisticated threat, no code on disk, hard to detect

Execution Methods

- Resides in system memory, uses scripting tools (e.g., PowerShell, WMI)
- Persistence via registry changes, no file-based methods

Detection Challenges

- "Live off the land" techniques, shellcode for stealth
- Part of APTs and AVTs, low observable characteristics, advanced evasion

Activity: 5 Second Game

You have 5 seconds to:

List 5 Types of Cyber Attacks

- External threats (hackers, cybercriminals, espionage, competitive intelligence)
- Internal threats (accidental data leaks, deliberate data theft, sabotage, insider trading)
- Enumeration attacks (footprinting, fingerprinting)
- Denial of service attacks (ICMP flood, SYN flood, DNS amplification)
- Botnet attacks (DDOS, spam botnets, banking trojan botnets)
- Malware (viruses, worms, trojan, PUP, PUA)



Lesson 9.3

Spoofing Attacks

Spoofing Attacks

Definition

- Disguising oneself as someone else to gain unauthorized access

Purpose

- Trick users/devices, bypass security, and steal data or spread malware

Types

- IP spoofing
- ARP spoofing
- Email spoofing

On-Path Attacks

Definition

- Attacks that intercept and possibly alter two parties' communications undetected

Purpose

- Steal sensitive personal or corporate information
- Inject malware

Common Types

- Session hijacking
- SSL stripping
- DNS spoofing
- Wi-Fi eavesdropping
- ARP spoofing

ARP Spoofing Example

No.	Time	Source	Destination	Protocol	Length	Info
6	10.022521400	Microsof_01:ca:4a	Microsof_01:ca:76	ARP	42	10.1.0.102 is at 00:15:5d:01:ca:76
7	10.032593900	Microsof_01:ca:4a	Microsof_01:ca:77	ARP	42	10.1.0.2 is at 00:15:5d:01:ca:77
8	10.032605300	Microsof_01:ca:4a	Microsof_01:ca:76	ARP	42	10.1.0.101 is at 00:15:5d:01:ca:76
9	18.219200600	10.1.0.101	10.1.0.2	TCP	66	1702 → 80 [SYN] Seq=0 Win=65535 Len=0
10	18.220473400	10.1.0.101	10.1.0.2	TCP	66	[TCP Out-Of-Order] 1702 → 80
11	18.223616200	10.1.0.2	10.1.0.101	TCP	66	80 → 1702 [SYN, ACK] Seq=0 Ack=1 Len=0
12	18.228456800	10.1.0.2	10.1.0.101	TCP	66	[TCP Retransmission] 80 → 1702
13	18.228797700	10.1.0.101	10.1.0.2	TCP	54	1702 → 80 [ACK] Seq=1 Ack=1 Len=0
14	18.229264100	10.1.0.101	10.1.0.2	HTTP	433	GET / HTTP/1.1
15	18.238162600	10.1.0.101	10.1.0.2	TCP	54	1702 → 80 [ACK] Seq=1 Ack=1 Len=0
16	18.238250400	10.1.0.101	10.1.0.2	TCP	433	[TCP Retransmission] 1702 → 80
17	18.239342200	10.1.0.2	10.1.0.101	HTTP	412	HTTP/1.1 302 Redirect (text/html)
18	18.244530700	10.1.0.2	10.1.0.101	TCP	412	[TCP Retransmission] 80 → 1702
19	18.245021200	10.1.0.101	10.1.0.2	TCP	54	1702 → 80 [ACK] Seq=380 Ack=1 Len=0
20	18.252481800	10.1.0.101	10.1.0.2	TCP	54	[TCP Dup ACK 19#1] 1702 → 80
21	18.255190400	10.1.0.101	10.1.0.2	TCP	66	1703 → 443 [SYN] Seq=0 Win=65535 Len=0
22	18.260503200	10.1.0.101	10.1.0.2	TCP	66	[TCP Retransmission] 1703 → 443
23	18.261065300	10.1.0.2	10.1.0.101	TCP	66	443 → 1703 [SYN, ACK] Seq=0 Ack=1 Len=0
24	18.268454300	10.1.0.2	10.1.0.101	TCP	66	[TCP Retransmission] 443 → 1703

▶ Frame 9: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface 0
 ▼ Ethernet II, Src: Microsof_01:ca:77 (00:15:5d:01:ca:77), Dst: Microsof_01:ca:4a (00:15:5d:01:ca:4a)
 ▶ Destination: Microsof_01:ca:4a (00:15:5d:01:ca:4a)
 ▶ Source: Microsof_01:ca:77 (00:15:5d:01:ca:77)
 Type: IPv4 (0x0800)

ARP Spoofing Example

The image shows a Wireshark capture of an ARP spoofing attack. The packet list at the top shows three packets:

No.	Time	Source	Destination	Protocol	Info
1	0.000000000	00:0c:29:e2:18:b4	50:78:b3:f3:cd:f4	ARP	Who has 192.168.1.1? Tell 192.168.1.25
2	0.001271501	50:78:b3:f3:cd:f4	00:0c:29:e2:18:b4	ARP	192.168.1.1 is at 50:78:b3:f3:cd:f4
3	0.393554684	00:0c:29:e2:18:b4	00:0c:29:98:c7:a8	ARP	192.168.1.1 is at 00:0c:29:e2:18:b4

The packet details pane for Frame 3 (ARP reply) is expanded, showing the following fields:

- Hardware type: Ethernet (1)
- Protocol type: IPv4 (0x0800)
- Hardware size: 6
- Protocol size: 4
- Opcode: reply (2)
- Sender MAC address: 00:0c:29:e2:18:b4
- Sender IP address: 192.168.1.1
- Target MAC address: 00:0c:29:98:c7:a8
- Target IP address: 192.168.1.12

A warning message at the bottom of the packet details pane states: "[Duplicate IP address detected for 192.168.1.1 (00:0c:29:e2:18:b4) - also in use by 50:78:b3:f3:cd:f4 (frame 2)]".

MAC Flooding Attacks

Definition

- Overloads switch CAM table with many MAC addresses, causing switch failure and traffic broadcast

Purpose

- Disrupt switch function to eavesdrop on normally inaccessible network traffic

Types of MAC Flooding Attacks

- Random MAC address flooding
- Incremental MAC address flooding
- Targeted MAC flooding

VLAN Hopping Attack

Definition

- Exploit where attackers send packets to a VLAN without access, using vulnerabilities in VLAN implementation on switches

Purpose

- Bypass security, accessing restricted/sensitive networks

Types

- Switch Spoofing
- Double Tagging

Activity: Fill in the Blank

1. Two types of _____ hopping attacks include switch spoofing and double tagging.
2. A/an _____ attack involves intercepting and possibly altering two parties' communications without detection.
3. A/an _____ flooding attack overloads switch CAM table with many addresses, causing switch failure and traffic broadcast

Activity: Fill in the Blank

1. Two types of VLAN hopping attacks include switch spoofing and double tagging.
2. A/an on-path attack involves intercepting and possibly altering two parties' communications without detection.
3. A/an MAC flooding attack overloads switch CAM table with many addresses, causing switch failure and traffic broadcast

Lesson 9.4

Rogue System Attacks

Rogue Devices and Services

Definition

- Unauthorized hardware and software that connect to a network without permission, potentially causing serious security risks

Characteristics

- Unauthorized access
- Malicious intent
- Data interceptions and manipulation

Rogue DHCP Server Attacks

Definition

- An unauthorized DHCP server distributing incorrect network configuration parameters to clients

Characteristics

- Distribution of invalid configuration
- Traffic redirection
- On-path attacks

DNS Attacks

Definition

- Attacks that target the DNS, undermining the integrity and availability of internet services

Characteristics

- Disruption of service
- Domain hijacking
- Cache poisoning

Activity: Two Truths and a Lie

Rogue devices and services are unauthorized hardware and software that connect to a network without permission, potentially causing serious security risks

Rogue DNS Server Attacks involve an unauthorized server distributing incorrect network addresses to clients



DNS Attacks target the system which translates domain names into IP addresses, undermining the integrity and availability of internet services

Activity: Two Truths and a Lie

LIE

Rogue devices and services are unauthorized hardware and software that connect to a network without permission, potentially causing serious security risks

Rogue DNS Server Attacks involve an unauthorized server distributing incorrect network addresses to clients

DNS Attacks target the system which translates domain names into IP addresses, undermining the integrity and availability of internet services



Lesson 9.5

Social Engineering

Social Engineering Attacks

Definition

- Manipulative technique cyber criminals use to exploit human vulnerabilities, not technical weaknesses

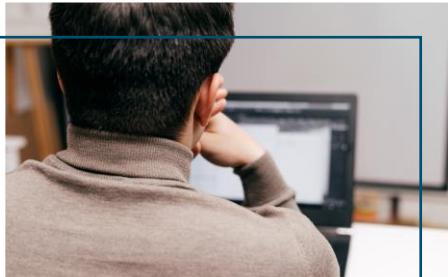
Goal

- Deceive individuals into giving up confidential or personal information

Characteristics

- Highly effective due to exploiting people's natural tendency to trust
- Success relies on the attacker appearing trustworthy or authoritative
- Persuades victims to breach security practices or ignore red flags

Types of Social Engineering Attacks



Shoulder Surfing



Dumpster Diving



Tailgating/Piggybacking



Phishing

Password Attacks

Definition

- Attempts to obtain or bypass individuals' passwords using various methods

Dictionary Attacks

- Enters all dictionary words
- Targets weak, simple passwords

Brute Force Attacks

- Tries all character combinations
- Time-consuming but cracks any password

Summary

- **Policies & Controls:** Establish policies and deploy controls aligned with the CIA triad (Confidentiality, Integrity, Availability)
- **Assessment & Monitoring:** Use tools and processes to continuously evaluate vulnerabilities, threats, and risk
- **Awareness Training:** Educate users on common attacks like footprinting, spoofing, DoS, DNS manipulation, VLAN hopping, malware, password cracking, and social engineering